

金老佛爺 × CHIC KIM & MIU

行動應用程式串接開發手冊

iOS / Android 開發人員適用

文件編號	CKMU-DEV-2026-003
版本	v1.0
發行日期	2026-08-03
適用對象	App 開發人員 (iOS / Android)
維護單位	CKMU 技術端
機密等級	內部文件，請勿對外散布

本手冊說明行動應用程式與 CHIC KIM & MIU 後端系統之串接方式，涵蓋會員認證、金老佛爺內容模組、商城模組、點數制度與上架前檢核項目。本文件與線上規格（repo 內 docs/api/v1.md）如有出入，以線上規格為準。

修訂紀錄

版本	日期	修訂內容	修訂人
v1.0	2026-08-03	初版發行；含社群登入（Google / Apple）與閱讀獎勵 API	技術端

目錄

1	系統概觀
2	環境與共通規範
3	會員認證
4	金老佛爺內容模組
5	商城模組
6	點數制度
7	推播與 Deep Link
8	功能現況一覽
9	上架前檢核表
10	串接自測指令

1. 系統概觀

本 App 同時承載兩個品牌介面：金老佛爺（Kim Lafayette）內容面與 CHIC KIM & MIU（下稱 CKMU）商城面。兩者共用同一個後端與同一份會員資料庫，會員在網站、部落格或 App 任一端註冊與消費，帳號、點數與訂單均為同一份資料，無需任何同步機制。

App 端僅需對接 CKMU 後端（單一 API 網域）。金老佛爺之文章內容亦由 CKMU 後端提供（見第 4 章），App 不需連線 kimlafayette.com 任何主機。



1.1 品牌面與資料來源

品牌面	內容	資料來源
金老佛爺	部落格文章、穿搭內容、閱讀獎勵	CKMU 後端 blog-posts (feed API)
CKMU 商城	商品、購物車、結帳、訂單、點數、遊戲、會員	CKMU 後端全套 API

會員身分比對規則（後端統一處理）：先以社群帳號識別碼（socialLogins）比對，其次以已驗證之 email 比對，均無則建立新會員。App 端不需理解此規則細節，僅需知道：同一使用者由網站或 App 登入，都會對應到同一個會員。

2. 環境與共通規範

2.1 環境

環境	Base URL	說明
封測（現行）	https://pre.chickimmiu.com	目前唯一環境，資料為正式資料
正式（切換後）	https://www.chickimmiu.com	上線時切換，兩網域並行一段時間

- Base URL 須為可設定值（remote config 或 build flavor），不得寫死於程式。
- /api/** 路徑不會回應 301 轉址；若收到 3xx 表示路徑有誤，不得自動跟隨。
- 全程 HTTPS。憑證為 Let's Encrypt，約 90 天輪替，如自行實作 certificate pinning 請留意。

2.2 認證通則

取得 token 後（方式見第 3 章），所有需會員身分之 API 均帶下列 header：

```
Authorization: Bearer <token>
```

- Token 效期 7 天（登入回應之 expiresIn，單位秒）。過期後 API 回 401，App 應引導重新登入。
- 目前未提供 refresh token。社群登入可於收到 401 時靜默重跑一次系統 SDK 取得新 token；email 登入則需重新輸入密碼。
- 不需 cookie 與 CSRF token。

- Token 為 JWT 格式，但 App 端不得自行解析其內容作為業務判斷依據，一律以 API 回傳資料為準。

2.3 錯誤格式

```
{ "success": false, "error": "<可直接顯示的中文訊息>", "code": "<機器碼>" }
```

code	HTTP	處理方式
BAD_REQUEST	400	參數缺漏或格式錯誤，開發階段即應排除
UNAUTHORIZED	401	token 過期或無效，走重新登入流程
INVALID_ID_TOKEN	401	社群登入 id_token 驗證失敗，見 3.4 排查表
FORBIDDEN	403	權限不足；遊戲 API 附 requiresTermsAcceptance 時須先完成規範同意
PROVIDER_DISABLED	403	該社群登入未啟用（後台開關或憑證未設定）
NOT_FOUND	404	資源不存在
INTERNAL_ERROR	500	顯示通用錯誤訊息並提供重試

注意：部分較早期之 endpoint（如 /api/payment/ecpay/create）僅回傳 { "error": "..." }，無 success 欄位。錯誤判斷一律以 HTTP 狀態碼 ≥ 400 為準。

2.4 分頁與圖片

v1 系列列表 API 之分頁格式如下：

```
{ "success": true, "data": [ ... ],  
  "meta": { "page": 1, "totalPages": 8, "totalDocs": 152,  
            "hasNextPage": true, "hasPrevPage": false } }
```

- 金老佛爺 feed API 回傳之圖片為絕對 URL，可直接載入。
- 其餘 API 之 media 物件 url 可能為相對路徑（/api/media/file/...），須自行補上 Base URL。
- 圖片存放於 CDN 物件儲存，支援標準 HTTP 快取；App 端應啟用 image cache。

3. 會員認證

3.1 登入方式一覽

方式	Endpoint	平台	狀態
Email+密碼	POST /api/v1/auth/login	全部	可用
Google 原生	POST /api/v1/auth/social	iOS / Android	程式就緒，待憑證
Apple 原生	POST /api/v1/auth/social	iOS（必要，見下註）	程式就緒，待憑證
LINE	—	—	App 原生未支援，請勿以 WebView 方式硬接
註冊 (email)	POST /api/users/register	全部	可用；成功後另呼叫 login 取 token

註：依 App Store 審查規範，App 若提供任何第三方登入（如 Google），即必須同時提供 Sign in with Apple，否則將無法通過審查。

3.2 Google / Apple 原生登入流程

原生登入採「App 以系統 SDK 取得 id_token，交由後端驗證換發自家 token」模式，全程不經瀏覽器轉址：



Request：

```
POST /api/v1/auth/social
Content-Type: application/json

{
  "provider": "google",          // 或 "apple"
  "idToken": "<SDK 取得之 id_token>",
  "nonce": "<步驟 1 之 nonce 原文>", // 建議必帶（防重放）
  "name": "王小明"              // Apple 首次登入務必帶，見 3.3
}
```

Response 200：

```
{
  "success": true,
  "data": {
    "token": "<JWT>",
    "expiresIn": 604800,
    "isNewUser": true,          // true 時可進入新手引導流程
    "user": { "id": 1234, "email": "...", "name": "...", "points": 0,
              "shoppingCredit": 0, "memberTier": { ... } }
  }
}
```

3.3 平台實作要點

平台	要點
iOS (Google)	使用 Google Sign-In SDK。後端須先登記 App 之 iOS Client ID，否則 audience 檢查不通過。
Android (Google)	使用 Credential Manager (Sign in with Google)。以實測取得之 id_token audience 為準，向後端登記對應的 Client ID。
iOS (Apple)	使用 ASAuthorizationAppleIDProvider。nonce 於 SDK 端送 SHA-256 雜湊值、POST 給後端時送原文（後端兩種格式均可比對）。後端須登記 App 之 Bundle ID。

注意：Apple 僅於使用者「首次授權」時提供 email 與姓名。首次登入務必將 fullName 組成字串放入 name 欄位一併送出；錯過後 Apple 不再提供，會員名稱將以 email 前綴代替。使用者若選擇「隱藏我的電子郵件」，將取得 privaterelay.appleid.com 轉發信箱，屬正常會員資料，照常處理。

3.4 INVALID_ID_TOKEN 排查

情境	原因
初次串接即 401	App 之 iOS / Android Client ID 尚未登記至後端「社群登入設定」
Google 可、Apple 不可	Bundle ID 未登記，或 nonce 誤送雜湊值（應送原文）
偶發 401	id_token 逾時。SDK 取得後應立即送出交換，不得暫存
模擬器可、實機不可	實機簽章（SHA-1 / Team）與開發者後台登記不符

3.5 會員資料與登出

- App 啟動或回前景時呼叫 GET /api/v1/me，一次取得會員資料、錢包（points / shoppingCredit / storedValueBalance）、寶物箱摘要與遊戲規範狀態。呼叫間隔不得低於 5 秒。
- 會員等級顯示名稱使用 user.memberTier.frontName（男女會員顯示名不同，由後端決定，App 不得自行對應）。
- gameTerms.requiresAcceptance 為 true 時，進入遊戲前須完成規範同意（POST /api/games/accept-terms）。
- 登出：刪除本地 token 即可；如需伺服器端撤銷，另呼叫 POST /api/users/logout。

4. 金老佛爺內容模組

4.1 文章資料來源

文章列表與內文一律取自 GET /api/kim-blog/feed（免登入）。回應含全部已發佈文章（發佈時間新至舊排序），並支援 ETag 條件請求：

```
GET /api/kim-blog/feed
If-None-Match: "<上次回應之 ETag>" → 304 時沿用本地快取
Cache-Control: public, max-age=60, stale-while-revalidate=300
```

回應主要欄位：

```
{
  "version": 1,
  "generatedAt": "2026-08-01T12:00:00.000Z", // 內容版本指紋
  "posts": [{
    "slug": "seoul-fashion-week-2026", // 閱讀獎勵 API 使用此值
    "title": "...", "excerpt": "...",
    "excerptCta": { "enabled": true, "label": "立即購買", "url": "..."}, // 或 null
    "visibility": "public", // public / unlisted / password
    "category": "...", "tags": [ "..."],
    "publishedAt": "...", "viewCount": 1234,
    "featuredImage": "https://...", // 絕對 URL
    "html": "<p>...</p>", // 內文（已序列化之 HTML）
    "images": [{ "src": "https://..." }]
  }]
}
```

4.2 顯示規範

- 內文為 HTML 字串，以 WebView 或 HTML renderer 呈現；圖片皆為絕對 URL。
- 完整 feed 可能達數 MB，ETag 快取為必要實作；列表頁僅解析 title / excerpt / featuredImage。
- visibility 為 public 者正常顯示；unlisted 不列入列表（持 slug 才可開啟）；password 本版不支援，直接不顯示。
- excerptCta 有值時，於文章卡片與內文顯示行動按鈕；URL 指向商城商品頁者，應攔截為 App 內原生商品頁（見第 7 章）。
- 文章瀏覽統計：POST /api/kim-blog/analytics/track（body 帶 slug；免登入，送出後不需處理回應）。

4.3 閱讀獎勵 (read-reward)

發放規則（後端可調整，以下為現行值）：

項目	規則
每篇文章	5 點，乘以會員等級／訂閱倍率後無條件捨去，最少 1 點
每人每篇	終身一次
每人每日	3 篇（以台北時區換日）
最短停留	20 秒（App 端計時，未達不送出）

App 專用 endpoint（Bearer 認證）：

```
POST /api/v1/points/read-reward
Authorization: Bearer <token>
```

```
{ "slug": "<feed 之 slug 欄位值>", "dwell_seconds": 25 }
```

Response 200（未發點並非錯誤，App 靜默處理即可）：

```
{ "awarded": 5, "points": 585, "reason": null }           // 發點成功  
{ "awarded": 0, "points": 580, "reason": "already_rewarded" } // 此篇已領  
{ "awarded": 0, "points": 580, "reason": "daily_limit" }   // 當日已達上限  
{ "awarded": 0, "points": null, "reason": "dwell_too_short" } // 停留不足
```

- 計時規則：文章頁可見時間累計，App 切至背景時暫停；滿 20 秒才送出。
- 發點成功後，畫面點數餘額直接以回傳之 points 更新（已含倍率計算）。
- 每篇文章送出一一次即可；收到 already_rewarded 後不需再送同篇。

注意：/api/sso/points/read-reward 為部落格網站伺服器端專用介面（需 client secret），App 不得使用該路徑，secret 亦不得打包進 App。兩介面於後端共用同一份防重複規則，同一篇文章在部落格與 App 只會發放一次。

4.4 設計限制

- 不得以 WebView 載入 blog.kimlafayette.com 作為內容面：該站會員 session 與 App token 為兩套機制，點數狀態無法一致。內容一律經由 feed API 原生渲染。
- 不得抓取 www.kimlafayette.com 之 HTML 頁面內容。

5. 商城模組

5.1 商品、推薦與 UGC

功能	Endpoint	認證
商品列表	GET /api/v1/products?page=&limit=&category=&tag=new hot&sort=&search=&minPrice=&maxPrice=	免
商品詳情	GET /api/products/<id>	免
推薦商品	GET /api/v1/recommendations?type=trending similar also_bought personalized body_match&productId=&userId=&limit=4	免
UGC 內容牆	GET /api/v1/ugc?page=&limit=&platform=&location=	免

- limit 上限：products 100、ugc 50。
- 列表僅含上架中商品；詳情頁 404 即為已下架，顯示對應狀態。
- 價格以 API 回傳為準。加購、滿贈、組合價之計算均由後端處理，App 不得自行運算折扣。

5.2 購物車

購物車為 App 本地狀態（後端無購物車資料表）。結帳前以下列 API 校驗：

功能	Endpoint
套用優惠券	POST /api/cart/apply-coupon
滿額贈查詢	POST /api/cart/gifts
加購品查詢	POST /api/cart/add-ons
結帳設定（運費／門檻／付款方式）	GET /api/checkout-settings

5.3 結帳與綠界付款（二段式）

1. POST /api/orders (Bearer；建立 pending / unpaid 訂單)
body: items[]、收件資訊、paymentMethod: "ecpay"、shippingMethod ...
→ 取得 orderNumber
2. POST /api/payment/ecpay/create body: { "orderNumber": "..."}
→ { "action": "<綠界結帳 URL>",
"params": { MerchantID, MerchantTradeNo, CheckMacValue, ... } }
3. App 開啟 WebView，將 params 組成 <form method="POST" action="{action}"> 自動送出 → 使用者於綠界頁完成付款
4. 綠界以伺服器對伺服器方式回報後端（App 無需處理 callback）。
WebView 偵測導回 /checkout/success* 後關閉，重新查詢訂單確認狀態

- 付款頁必須使用 WebView（綠界代管頁面）。App 不得自行蒐集卡號（PCI 規範）。
- 付款成功與否以重新查詢訂單之 paymentStatus == "paid" 為準，不得僅依 WebView 導回網址判斷。
- ATM／超商代碼為非同步付款：使用者取得繳費資訊後訂單維持 pending，App 須有「待付款」狀態與繳費資訊顯示。
- 未付款訂單由後端排程自動取消（約 10 分鐘級距），訂單列表須能反映 cancelled 狀態。
- 超商取貨門市地圖之 App 內整合尚未定案，本版先支援宅配與既有門市手動填寫。

5.4 訂單

功能	Endpoint
我的訂單	GET /api/orders?where[user][equals]=<userId> (僅能查詢本人訂單)
取消訂單	POST /api/account/orders/<id>/cancel

5.5 點數商城、寶物箱與遊戲

功能	Endpoint	說明
可兌換清單	GET /api/v1/points	免登入可瀏覽
兌換	POST /api/v1/points	Bearer。類型含實體贈品／優惠券／購物金／抽獎等，結果進入寶物箱
寶物箱	GET /api/user-rewards?where[user][equals]=<id>	實體獎品 (requiresPhysicalShipping) 由後端自動附掛於下一筆訂單
電子券核銷	POST /api/user-rewards/consume	body: { rewardId }
遊戲總覽	GET /api/games	簽到／轉盤／刮刮樂／電影抽獎／穿搭挑戰
進行遊戲	POST /api/games	{ action: "checkin" } 或 { action: "play", gameType: ... }
規範同意	POST /api/games/accept-terms	收到 403 requiresTermsAcceptance 時先行呼叫

點數餘額一律以 /api/v1/me 之 wallet.points 為準，App 不得自行累加後顯示。點數異動歷史可查 GET /api/points-transactions?where[user][equals]=<id>&sort=-createdAt。

5.6 訂閱會員

- 方案列表：GET /api/subscription-plans。
- 訂閱與解約流程本版以 WebView 導向網站 /subscription 處理（首期綁卡為綠界代管頁面）。
- 訂閱權益（點數倍率、購物金、結帳折扣）由後端自動生效，App 無需另行處理。

6. 點數制度

來源	規則	App 對應位置
消費回饋	依後端規則，乘以等級／訂閱倍率	付款完成後自動入點
金老佛爺閱讀獎勵	每篇 5 點、每日 3 篇，同倍率	內容面（見 4.3）
每日簽到／遊戲	依各遊戲規則	遊戲面
兌換	扣點	點數商城

等級與訂閱倍率由後端統一計算，兩品牌共用同一套規則。App 僅顯示後端回傳數字。

7. 推播與 Deep Link

- 推播（FCM／APNs）後端尚未建置。本版採「回前景時刷新 /api/v1/me 與訂單列表」策略；訂單狀態通知暫由 Email 與 LINE 送達。

Deep Link 建議同時支援自訂 scheme 與 Universal / App Links：

連結	導向
chickimmiu://products/<id>	商品頁
chickimmiu://orders/<id>	訂單詳情
chickimmiu://games、chickimmiu://games/scratch-card	遊戲
chickimmiu://account/treasure	寶物箱
chickimmiu://blog/<slug>	金老佛爺文章

Universal Links 網域：www.chickimmiu.com（正式環境切換後）。

8. 功能現況一覽

截至本文件發行日之各項目狀態。標示「待憑證」「規劃中」者，後端均已有既定方案，App 端依表預留即可，不得自行繞路實作。

項目	狀態	App 端因應
Email 登入／註冊、會員資料、商品、遊戲、點數商城、寶物箱	可用	—
金老佛爺 feed 與文章	可用	—
閱讀獎勵 /api/v1/points/read-reward	可用（2026-08-03 上線）	依 4.3 串接
Google／Apple 原生登入	程式就緒，待憑證申請與 App Client ID 登記	先行整合 SDK；401 屬預期
綠界付款	沙盒可測；正式商店尚無實際交易	流程依 5.3
超商取貨門市地圖	App 整合待定	先支援宅配
LINE 原生登入	未支援	本版不做
推播（FCM／APNs）	未建置	拉取式更新
伺服器端流量限制	未實施	遵守自律規範（me 間隔 5 秒以上；遊戲按鈕待回應）

9. 上架前檢核表

1. Base URL 可切換（pre 與 www）
2. 提供 Google 登入時，Apple 登入亦已提供；Apple 首次登入有送出 fullName
3. Token 過期（401）時靜默重登或導向登入頁，不得閃退
4. 綠界 WebView：付款結果以訂單 paymentStatus 為準；ATM／超商代碼有待付款介面
5. 金老佛爺 feed 具 ETag 快取；visibility 非 public 之文章不顯示
6. 點數與餘額均顯示後端回傳數字，無本地運算
7. 遊戲 403 requiresTermsAcceptance 有對應之規範同意流程
8. 深色模式下介面邊線具明度對比（對比值 3:1 以上，不得僅以色相區分）

10. 串接自測指令

```
# 金老佛爺文章 feed (免登入)
curl -s https://pre.chickimmiu.com/api/kim-blog/feed | head -c 600

# 商品列表
curl -s "https://pre.chickimmiu.com/api/v1/products?limit=2&tag=hot"

# email 登入後取會員資料
TOKEN=$(curl -s -X POST https://pre.chickimmiu.com/api/v1/auth/login \
  -H 'Content-Type: application/json' \
  -d '{"email":"<測試帳號>","password":"<密碼>"}' | jq -r .data.token)
curl -s https://pre.chickimmiu.com/api/v1/me \
  -H "Authorization: Bearer $TOKEN"

# 社群登入 (憑證登記後)
curl -s -X POST https://pre.chickimmiu.com/api/v1/auth/social \
  -H 'Content-Type: application/json' \
  -d '{"provider":"google","idToken":"<SDK id_token>","nonce":"<原文>"}'

# 閱讀獎勵 (slug 取自 feed)
curl -s -X POST https://pre.chickimmiu.com/api/v1/points/read-reward \
  -H "Authorization: Bearer $TOKEN" -H 'Content-Type: application/json' \
  -d '{"slug":"<slug>","dwell_seconds":25}'
```

問題回報請附：endpoint、request body (去除個資)、response 全文與發生時間。規格異動將以修訂版本發行，並同步更新 repo 內 docs/api/v1.md。